

YFD FIRST AID

Data Privacy, User Access & Informed Consent — Product & IT Requirement

Dokumen	YFD First Aid — Data Privacy, User Access & Informed Consent
Versi	1.1 (Revisi)
Tanggal	14 Agustus 2026
Status	Siap Review IT — dasar hukum UU PDP ditambahkan, 3 keputusan kebijakan sudah dikunci (lihat Bagian 10-11)
Disiapkan oleh	dr. Ayuti Bulaan, QWP — Your Financial Doctor (YFD)
Penanggung Jawab Data (informal)	dr. Ayuti Bulaan, QWP & dr. Catherina, QWP

1. Tujuan Dokumen

Dokumen ini menjadi requirement untuk implementasi keamanan akses data dan mekanisme persetujuan pengguna (Informed Consent) pada YFD First Aid. YFD First Aid dapat memproses data transaksi finansial, informasi Financial Health, pola transaksi, konteks transaksi, mood, data perilaku, hasil assessment, serta data lain yang dimasukkan pengguna.

Sistem harus dirancang agar data setiap pengguna bersifat private, terpisah dari pengguna lain, dan hanya dapat diakses sesuai hak akses yang telah ditentukan.

DASAR HUKUM: Dokumen ini disusun mengacu pada Undang-Undang No. 27 Tahun 2022 tentang Pelindungan Data Pribadi (UU PDP). Referensi pasal spesifik dicantumkan di setiap bagian yang relevan.

2. Dasar Hukum & Klasifikasi Data

UU PDP membagi data pribadi menjadi dua kategori: data umum (nama, jenis kelamin, kewarganegaraan, dll.) dan data pribadi spesifik, yang mendapat standar perlindungan lebih ketat.

Data yang diproses YFD First Aid — data transaksi finansial dan data perilaku/mood terkait kondisi kesehatan finansial pengguna — termasuk dalam kategori data pribadi spesifik (data keuangan, dan berpotensi bersinggungan dengan data kesehatan). Implikasinya:

- Consent untuk data spesifik harus eksplisit dan jelas tujuannya (tidak boleh tersirat atau otomatis).
- Standar keamanan teknis untuk data spesifik lebih tinggi dibanding data umum.
- Kewajiban notifikasi lebih ketat apabila terjadi insiden kebocoran (lihat Bagian 12).

CATATAN IT: Implikasi teknis: field data transaksi, mood, dan hasil assessment sebaiknya diberi flag/tag 'data spesifik' di level database, supaya kebijakan akses dan enkripsi bisa diterapkan berbeda dari data umum (nama, kontak) jika diperlukan di iterasi berikutnya.

3. Prinsip Utama

PRINSIP DASAR

Setiap pengguna hanya dapat mengakses data yang terkait dengan akun miliknya sendiri.

- User A tidak boleh dapat melihat data User B.

- Dashboard hanya menampilkan data milik user yang terautentikasi.
- Transaksi, assessment, pola perilaku, dan data Financial Health harus terikat pada unique internal user_id.
- Pembatasan akses wajib diterapkan pada Backend/API, bukan hanya tampilan frontend.
- Akses internal ke data individual YFD TIDAK bersifat otomatis.

4. Requirement User Data Isolation

Setiap data harus memiliki relasi yang jelas dengan unique internal user_id.

ALUR

Authenticated User → internal user_id → transaksi / assessment / dashboard / hasil analisis milik user tersebut.

- Telegram ID dapat digunakan untuk integrasi, tetapi sistem disarankan tetap memiliki internal user_id.
- Setiap request membaca, mengubah, menghapus, atau menampilkan data harus memverifikasi identitas dan ownership.
- User tidak boleh dapat mengakses data pengguna lain dengan mengubah URL, parameter, dashboard ID, transaction ID, atau identifier lainnya.

5. Authentication & Authorization

Authentication menjawab: siapa pengguna yang sedang menggunakan sistem? Authorization menjawab: apakah pengguna tersebut berhak mengakses data yang diminta?

REQUIREMENT

Authentication tanpa authorization yang memeriksa ownership data tidak dianggap cukup.

- Backend harus memverifikasi identity dari mekanisme autentikasi.
- Backend tidak boleh hanya mempercayai user_id yang dikirim bebas dari frontend.
- Request data yang bukan milik user harus ditolak.
- Pembatasan tetap berlaku meskipun user mengetahui identifier data pengguna lain.
- Minimum Necessary Access: jika user memberikan persetujuan untuk akses internal, pihak internal hanya boleh melihat data minimum yang relevan dengan tujuan layanan tersebut.

6. Akses Internal YFD

PRINSIP DEFAULT

Data individual user bersifat PRIVATE. Tidak ada akses internal otomatis hanya karena seseorang memiliki role di YFD.

- User: hanya dapat melihat dan mengelola data miliknya sendiri.
- Admin operasional: tidak memiliki akses otomatis ke data individual. Akses hanya dapat diberikan apabila diperlukan untuk kepentingan layanan user, dengan persetujuan user terlebih dahulu dan hanya pada data yang diperlukan.
- Developer/IT: tidak memiliki akses bebas ke data individual production. Akses hanya dapat dilakukan apabila benar-benar diperlukan untuk kepentingan layanan user, dengan persetujuan user terlebih dahulu, serta dibatasi pada data minimum yang diperlukan.

- Doctor/Consultant YFD: hanya dapat mengakses data yang diperlukan untuk memberikan atau mendukung layanan yang diminta user, setelah mendapat persetujuan user.
- User lain: tidak memiliki akses sama sekali.

Akses internal hanya boleh dilakukan jika terdapat tujuan layanan yang jelas dan langsung berkaitan dengan kepentingan user. Akses tidak boleh dilakukan hanya untuk melihat-lihat, monitoring tanpa tujuan layanan, atau kepentingan internal yang tidak berkaitan dengan kepentingan user.

7. Penggunaan Data Agregat

Jika data digunakan untuk evaluasi atau pengembangan layanan, YFD dapat menggunakan data dalam bentuk agregat atau bentuk lain yang sesuai. Tujuannya untuk melihat pola keseluruhan, bukan memberikan pengguna lain akses terhadap data individual.

8. Hak Subjek Data (Sesuai UU PDP)

Selain hak isolasi data (Bagian 3-4), UU PDP memberikan hak tambahan ke setiap pengguna sebagai subjek data. Hak-hak ini wajib dikomunikasikan di consent form dan didukung secara teknis, minimal secara manual di tahap awal ini.

Hak Akses & Salin Data

User berhak tahu data apa saja yang YFD simpan tentang mereka, dan meminta salinannya.

Hak Koreksi

User berhak meminta perbaikan data yang salah atau tidak akurat.

Hak Hapus (Right to Erasure)

User berhak meminta datanya dihapus, dengan pengecualian data yang wajib disimpan karena kewajiban hukum lain (mis. kewajiban pajak).

Hak Menarik Persetujuan

User berhak menarik consent kapan saja. Ini hak atas pemrosesan data, TERPISAH dari kebijakan refund pembayaran (lihat Bagian 11).

Hak Menolak Profiling Otomatis

First Aid melakukan profiling (Financial Health scoring, kategori FTSA). User berhak tahu profiling ini terjadi dan menanyakan dasarnya.

CATATAN IT: Di tahap awal ini, permintaan akses/koreksi/hapus data cukup ditangani manual oleh tim (via CS/kontak yang tercantum di consent form) — belum perlu dibangun self-service otomatis. Yang wajib ada: SOP internal + SLA waktu respons (rekomendasi: maksimal 14 hari kerja untuk merespons permintaan).

9. Kebijakan Retensi Data

KEBIJAKAN

Data disimpan selama akun kamu terdaftar di sistem YFD First Aid — termasuk saat berstatus tidak aktif karena belum melakukan pembayaran biaya admin tahunan — dan hanya dihapus apabila kamu secara eksplisit meminta penghapusan.

Konteks bisnis: aktivasi YFD First Aid bersifat sekali seumur hidup (bukan langganan berjangka dengan tanggal habis). Mulai tahun kedua, ada biaya admin (Rp 10.000/bulan atau Rp 99.000/tahun) untuk tetap bisa menggunakan sistem. Akun yang tidak membayar admin menjadi tidak aktif, namun TIDAK dihapus atau expired — data tetap tersimpan agar dapat diakses kembali begitu pembayaran dilakukan, kapan pun itu.

Karena tidak ada tanggal habis, secara praktik retensi data berlangsung selama akun tersebut ada di sistem YFD, yaitu berpotensi seumur hidup pengguna — kecuali pengguna secara eksplisit meminta penghapusan.

DASAR HUKUM: Kebijakan ini tetap konsisten dengan prinsip storage limitation UU PDP karena retensi terikat ke alasan yang jelas dan sah: pengguna telah membayar untuk hak akses seumur hidup, sehingga retensi data sepanjang masa berlaku itu proporsional terhadap tujuannya — bukan retensi tanpa syarat/tanpa alasan. Tetap hindari kata 'selamanya' tanpa konteks di komunikasi ke user; gunakan framing 'selama akun terdaftar (aktivasi seumur hidup)' seperti di atas supaya alasannya eksplisit.

CATATAN IT: Belum perlu automated deletion pipeline di tahap ini. Yang perlu ada: proses manual untuk menghapus data user yang secara eksplisit meminta (lihat Bagian 8), dicatat di log penghapusan. Catatan ke depan (bukan sekarang): karena tidak ada natural expiry, volume akun dorman jangka sangat panjang akan terus bertambah — worth direview sebagai isu biaya storage kalau basis user sudah besar, bukan isu kepatuhan.

10. Kebijakan Penarikan Persetujuan (Withdrawal of Consent)

PENTING — dua hal berikut terpisah dan tidak boleh disamakan:

- Refund / pengembalian uang — kebijakan bisnis YFD: TIDAK ADA REFUND setelah pembelian. Ini tidak berubah oleh bagian ini.
- Withdrawal of consent — hak subjek data untuk meminta pemrosesan datanya dihentikan. Hak ini tetap berlaku terlepas dari status pembayaran, dan TIDAK memicu kewajiban refund.

KEBIJAKAN UNTUK SKALA SAAT INI

Jika user meminta penarikan persetujuan pemrosesan data, permintaan diproses manual oleh tim (via kontak di consent form).

Akun disuspend — mirip status tidak aktif karena belum bayar admin — dan pemrosesan data aktif dihentikan.

Data ditangani sesuai permintaan user: dihapus jika diminta, atau tetap tersimpan-tapi-tidak-diproses jika user hanya ingin berhenti sementara.

Tidak ada refund atas biaya yang sudah dibayarkan.

CATATAN IT: Belum perlu tombol self-service 'withdraw consent' di produk pada tahap ini. Cukup sediakan kontak yang jelas di consent form dan Panduan, dan SOP manual internal untuk menangani permintaan ini. Bangun fitur otomatis kalau volume permintaan sudah terasa membebani tim manual.

11. Insiden Kebocoran Data (Breach Notification)

DASAR HUKUM: Pasal 46 UU PDP mewajibkan pengendali data memberi tahu subjek data yang terdampak DAN otoritas pengawas (saat ini di bawah Kementerian Komunikasi Digital) dalam waktu 3x24 jam (72 jam) sejak mengetahui adanya pelanggaran/kebocoran data pribadi. Pemberitahuan wajib mencantumkan data yang terdampak, kapan dan bagaimana insiden terjadi, dan langkah pemulihan yang sudah diambil.

- YFD wajib punya SOP internal: siapa yang harus segera tahu kalau ada indikasi kebocoran data (minimal: dr. Ayuti & dr. Catherina sebagai penanggung jawab data saat ini).
- Template notifikasi ke user dan draf pelaporan ke otoritas sebaiknya disiapkan di muka — jangan ditulis dari nol saat insiden benar-benar terjadi, karena jendela waktunya cuma 72 jam.
- IT perlu memastikan sistem punya cara mendeteksi & mencatat waktu 'pertama kali insiden diketahui' — ini yang jadi patokan hitung mundur 72 jam.

CATATAN IT: Ini bukan item yang bisa ditunda sampai skala besar — kewajiban 72 jam berlaku sejak hari pertama YFD memproses data pengguna, berapa pun jumlah usernya. Yang bisa ditunda hanya tingkat kecanggihan tooling deteksinya (lihat Bagian 13).

12. Informed Consent — Dua Lapis

Consent dibagi jadi dua momen berbeda, bukan satu:

Lapis 1 — Ringkasan Pra-Pembelian (di halaman beli, sebelum bayar)

Ditampilkan sebelum user memutuskan membeli. Tujuannya transparansi di titik keputusan finansial, bukan pengganti consent teknis — pada tahap ini belum ada user_id/akun yang bisa dikaitkan dengan consent record.

Lapis 2 — Consent Aktif Pasca-Aktivasi (di bot, setelah lisensi aktif)

Consent penuh dengan checkbox tercentang aktif, tersimpan sebagai consent record terikat ke user_id (Bagian 16). Ini yang jadi bukti hukum consent, bukan lapis 1.

CATATAN IT: Dua lapis ini saling melengkapi, bukan salah satu menggantikan yang lain. Lapis 1 mencegah keluhan 'saya tidak tahu data saya dipakai begini' sebelum orang bayar. Lapis 2 tetap wajib karena baru di titik itu ada akun yang bisa dikaitkan ke consent record versioning.

13. Flow Implementasi

- 1. User membuka halaman pembelian.
- 2. Ringkasan kebijakan privasi ditampilkan (Lapis 1) — link ke versi lengkap tersedia.
- 3. User melanjutkan pembelian.
- 4. Aktivasi lisensi di bot.
- 5. Lisensi berhasil diverifikasi.
- 6. Identifikasi / nama user.
- 7. Tampilkan Data Privacy & Informed Consent lengkap (Lapis 2).
- 8. User membaca informasi.
- 9. User mencentang persetujuan aktif.
- 10. Tombol 'Saya Setuju & Lanjutkan' menjadi aktif.
- 11. Sistem menyimpan bukti consent (terikat ke user_id).
- 12. User masuk ke onboarding YFD First Aid.

14. Draft Ringkasan Pra-Pembelian (Lapis 1)

BOT / USER-FACING TEXT

 Sebelum kamu lanjut ke pembayaran, ini ringkasan bagaimana YFD First Aid memproses datamu: Data transaksi dan Financial Health kamu bersifat pribadi, tidak bisa dilihat pengguna lain, dan hanya diakses tim internal jika benar-benar diperlukan untuk layanan kamu dan dengan persetujuanmu. Baca kebijakan privasi lengkap di [LINK] sebelum melanjutkan.

Tombol: [ Baca Kebijakan Lengkap] | [ Lanjut ke Pembayaran]

CATATAN IT: Isi halaman di balik [LINK] SAMA dengan teks informasional di Bagian 15 (data yang diproses, tujuan, akses, retensi, hak user, breach notification, dst.) — supaya user tidak membaca dua versi kebijakan yang berbeda. Yang TIDAK ikut ditampilkan di halaman ini: checkbox persetujuan dan tombol 'Saya Setuju & Lanjutkan' (Bagian 16) — itu action item yang baru relevan setelah ada user_id pasca-aktivasi. Jadi [LINK] cukup berupa halaman statis/read-only berisi teks Bagian 15, tanpa elemen interaktif consent.

15. Draft User-Facing Informed Consent Lengkap (Lapis 2)

JUDUL

 *Privasi Data & Persetujuan Penggunaan YFD First Aid*

PENGANTAR

Sebelum mulai menggunakan YFD First Aid, kami ingin kamu memahami bagaimana data yang kamu masukkan digunakan di dalam sistem.

DATA YANG DAPAT DIPROSES

Selama menggunakan YFD First Aid, kamu dapat memasukkan atau menghasilkan data seperti transaksi finansial, informasi Financial Health, pola penggunaan, konteks transaksi, mood, hasil assessment, serta data lain yang berkaitan dengan penggunaan fitur.

TUJUAN PENGGUNAAN

Data digunakan untuk menjalankan fitur YFD First Aid, termasuk pencatatan transaksi, pengelompokan berdasarkan sistem YFD, dashboard, analisis Financial Health, serta fitur atau layanan terkait yang kamu gunakan.

AKSES DATA

Data yang terkait dengan akunmu pada prinsipnya bersifat pribadi dan tidak dapat diakses oleh pengguna lain. Setiap pengguna hanya dapat mengakses data yang terkait dengan akun miliknya sendiri melalui mekanisme autentikasi dan pembatasan akses sistem.

AKSES INTERNAL YFD

Data individual kamu tidak dapat diakses oleh pihak internal YFD secara bebas.

Dalam kondisi tertentu, anggota tim YFD dapat meminta akses terhadap data tertentu apabila akses tersebut memang diperlukan untuk memberikan atau mendukung layanan yang kamu gunakan, misalnya konsultasi, bantuan teknis, atau penanganan masalah pada akunmu.

Akses tersebut memerlukan persetujuan kamu terlebih dahulu dan hanya dilakukan sejauh diperlukan untuk tujuan tersebut.

BERAPA LAMA DATA DISIMPAN (BARU)

Karena aktivasi YFD First Aid berlaku sekali seumur hidup (bukan langganan berjangka), akunmu tidak akan otomatis dihapus atau expired oleh sistem.

Data kamu disimpan selama akun kamu terdaftar di sistem YFD First Aid, termasuk saat tidak aktif karena belum membayar biaya admin tahunan.

Kamu bisa meminta penghapusan data kapan pun melalui WhatsApp Admin YFD di +62 851-1122-8911.

HAK KAMU SEBAGAI PENGGUNA (BARU)

Kamu berhak melihat, meminta salinan, meminta koreksi, atau meminta penghapusan datamu.

Kamu berhak menarik persetujuan pemrosesan data kapan pun. Ini terpisah dari kebijakan pembayaran — penarikan persetujuan tidak mengembalikan biaya yang sudah dibayarkan.

Kamu berhak tahu bahwa First Aid melakukan pengelompokan otomatis (Financial Health Bucket, kategori FTSA) berdasarkan data yang kamu masukkan.

KALAU TERJADI INSIDEN KEAMANAN DATA (BARU)

Kalau terjadi kebocoran data yang berdampak ke akunmu, kami akan memberitahumu secara tertulis paling lambat 3x24 jam sejak kami mengetahuinya, termasuk data apa yang terdampak dan langkah yang kami ambil.

PENGEMBANGAN & ANALISIS

YFD dapat menggunakan data penggunaan dalam bentuk yang sesuai untuk evaluasi, pengembangan, dan peningkatan layanan. Analisis agregat bertujuan melihat pola secara keseluruhan dan tidak dimaksudkan untuk memberikan pengguna lain akses terhadap data individual.

PENTING

YFD First Aid merupakan alat pencatatan, edukasi, dan pemahaman Financial Health. Hasil sistem tidak dimaksudkan sebagai jaminan hasil finansial tertentu.

16. Checkbox Persetujuan

- ☐ Saya telah membaca dan memahami informasi mengenai penggunaan dan akses data dalam YFD First Aid.
- ☐ Saya memahami bahwa data yang saya masukkan dapat digunakan untuk menjalankan fitur, dashboard, analisis, dan layanan terkait yang saya gunakan.
- ☐ Saya memahami bahwa data saya tidak ditujukan untuk dapat diakses oleh pengguna lain.
- ☐ Saya memahami dan menyetujui bahwa, apabila diperlukan untuk memberikan atau mendukung layanan yang saya gunakan, pihak internal YFD dapat meminta akses terhadap data saya, hanya setelah persetujuan saya dan sejauh diperlukan.
- ☐ Saya memahami hak saya untuk mengakses, mengoreksi, menghapus data, dan menarik persetujuan kapan pun — serta memahami bahwa penarikan persetujuan tidak mengembalikan biaya yang sudah saya bayarkan.
- ☐ Saya menyetujui pemrosesan data saya untuk penggunaan YFD First Aid sesuai informasi yang telah dijelaskan.

Tombol: Saya Setuju & Lanjutkan

Tombol dapat dibuat tidak aktif sampai seluruh persetujuan wajib dicentang.

II DITUNDA — Unbundle consent akses-internal dari consent inti

Saat ini kelima checkbox digabung jadi satu syarat lanjut. Untuk skala sekarang ini wajar dan umum dilakukan. Revisit bersama lawyer di legal review transisi PT — terutama sebelum due diligence investor — untuk menilai apakah consent akses internal perlu dipisah jadi opsional/independen dari consent inti pemakaian.

17. Data Consent Record — Wajib Disimpan

- internal user_id
- consent_version
- tanggal dan waktu persetujuan
- status consent: accepted / withdrawn (lihat Bagian 10 untuk penanganan withdrawal)
- metode pemberian consent: Telegram Bot atau Web
- versi teks consent yang disetujui

Jika isi consent berubah secara material, sistem perlu mendukung consent_version baru dan mekanisme peninjauan ulang sesuai kebijakan produk.

18. Penanggung Jawab Data

Penanggung jawab informal untuk urusan data/privasi saat ini: dr. Ayuti Bulaan, QWP dan dr. Catherina, QWP. Channel kontak untuk permintaan akses, koreksi, penghapusan data, atau penarikan persetujuan: WhatsApp Admin YFD di +62 851-1122-8911 — dicantumkan di consent form dan Panduan.

II DITUNDA — Penunjukan DPO formal

UU PDP Pasal 53 mewajibkan penunjukan Data Protection Officer (DPO) formal apabila pemrosesan data pribadi spesifik sudah berskala besar. YFD First Aid saat ini masih tahap awal/pilot dan kemungkinan besar belum memenuhi ambang ini. Revisit kebutuhan DPO formal saat: (1) transisi ke PT November 2026, atau (2) jumlah user aktif naik signifikan — mana yang lebih dulu tercapai.

19. Catatan Implementasi untuk IT

- Keamanan tidak dianggap cukup hanya karena dashboard tidak memiliki tombol untuk melihat user lain.
- Setiap endpoint data harus melakukan ownership check.
- Tidak ada akses internal ke data individual tanpa tujuan layanan yang jelas.
- Akses internal memerlukan persetujuan user terlebih dahulu.
- Akses internal dibatasi pada data minimum yang diperlukan untuk tujuan layanan yang disetujui.
- Consent harus dicatat sebagai tindakan aktif pengguna, terpisah untuk Lapis 1 (pra-pembelian, tidak terikat user_id) dan Lapis 2 (pasca-aktivasi, terikat user_id).
- User-facing privacy information sebaiknya dapat diakses kembali melalui Privacy, Panduan, atau Pengaturan.
- (Baru) Sistem perlu mencatat timestamp 'pertama kali insiden diketahui' untuk keperluan hitung mundur kewajiban notifikasi 72 jam (Bagian 11) — minimal berupa log manual di tahap awal.
- (Baru) Field data spesifik (transaksi finansial, mood, hasil assessment) sebaiknya diberi flag terpisah di database untuk memudahkan penerapan kebijakan akses/enkripsi berbeda di iterasi berikutnya.
- (Baru) Permintaan hak subjek data (akses/koreksi/hapus/withdraw) ditangani manual di tahap ini — belum perlu self-service otomatis (lihat Bagian 8 & 10).

20. Hal yang Perlu Dikonfirmasi oleh Tim IT

- Bagaimana mekanisme authentication user saat ini?
- Apa unique identifier utama setiap user?
- Bagaimana Telegram terhubung dengan dashboard web?
- Apakah backend sudah melakukan ownership / authorization check?
- Apakah URL atau parameter dapat dimanipulasi untuk mengakses data user lain?
- Bagaimana mekanisme permintaan akses internal setelah user memberikan persetujuan?
- Bagaimana sistem membatasi akses internal hanya pada data minimum yang diperlukan?
- Bagaimana consent disimpan dan diberi versioning, termasuk untuk dua lapis (pra-pembelian dan pasca-aktivasi)?
- Di mana data First Aid di-hosting — server di Indonesia atau luar negeri? Ini menentukan apakah ada ketentuan transfer data lintas negara yang perlu dicek ke legal.
- Siapa yang bertanggung jawab menerima alert pertama kali kalau ada indikasi insiden keamanan data, dan bagaimana alert itu sampai ke penanggung jawab data (Bagian 18) dalam hitungan jam, bukan hari?

21. Ringkasan Item yang Ditunda

Dua hal berikut sengaja tidak dibangun sekarang karena belum jadi kebutuhan di skala saat ini. Dicatat di sini supaya tidak hilang, bukan diabaikan:

- Penunjukan DPO formal — revisit saat transisi PT atau saat skala user naik signifikan (Bagian 18).
- Unbundle consent akses-internal dari consent inti — revisit di legal review sebelum due diligence investor (Bagian 16).
- Automated deletion pipeline & self-service untuk hak subjek data — revisit kalau volume permintaan manual mulai membebani tim (Bagian 8, 10, 19).